Final Project

Final Project

- Your task is to build an autonomous pen-testing agent.
- This task is intended to get you to design an agent, not just prompt one.

The Target

- We will be using the OWASP Juice Shop as our target. (https://owasp.org/www-project-juice-shop)
- You may install this locally using Docker or use one of the instances we are hosting in class.
- Instructions for local setup are in the final project README.

Learning Objectives

- Design and implement an autonomous agent loop with tools.
- Translate pen-testing methodology (reconnaissance, vulnerability discovery, exploitation, reporting) to machine executable logic.
- Evaluate how prompt engineering and tool design affect agent performance
- Experience practical limits of LLM driven automation on adversarial tasks.

Deliverables

- `agent/agent.py` : The agent loop. The stub defines the interface; you decide the architecture (ReAct, Plan-and-Execute, multi-agent, hierarchical)
- `agent/prompts/`: System prompt(s) and any task-decomposition prompts. Empty templates are provided.
- At least 3 new tools in agent/tools/ beyond the two reference tools. Tools must be substantive — a "wrapper that calls another tool" does not count. Examples of acceptable tools: SQL injection tester, JWT decoder/forger, XSS payload generator, directory brute-forcer, API fuzzer, business-logic probe.
- Final pentest report (reports/final_report.md) — Generated by your agent at the end of a run. Must include findings, severity, evidence, remediation.

What you should NOT change

- `eval/score.py` and `eval/harness.py`:
- `agent/llm.py`: The LLM abstraction is fixed so everyone competes on equal LLM footing
- `agent/tools/base.py`: the tool protocol

Questions?

Good Luck!